COURS PAR CORRESPONDANCE

ANALYSTE EN INFORMATIQUE

Sécurité informatique

Module

Systèmes, réseaux & SSI

Sécurité informatique

(Lecture recommandée)

Sommaire

I- Définition : 3

II- Terminologie de la sécurité informatique : 3

III- Les objectifs de la sécurité informatique : 4

IV- Les menaces : 4

IV-1- Les virus informatique : 4

IV-2- Les vers informatique : 6

IV-3- Les chevaux de troie : 6

IV-4- Les bombes logiques : 6

IV-5- Les mouchards (Spyware) : 7

IV-6- Les composeurs automatiques (Dialers) : 7

IV-7- Les canulars (Hoaxes) : 7

V- Les contres mesures : 8

V-1- Antivirus : 8

V-2 Anti spam : 9

V-3 Firewall (pare-feu) : 9

V-4- Spyware : 15

Lexique 18

I- Définition :

La sécurité informatique est l'ensemble des techniques qui assurent que les ressources du système d'information (matérielles ou logicielles) d'une organisation sont utilisées uniquement dans le cadre où il est prévu qu'elles le soient.

Faire de la sécurité sur un réseau consiste à s'assurer que celui qui modifie ou consulte des données du système en a l'autorisation et qu'il peut le faire correctement car le service est disponible.

II- Terminologie de la sécurité informatique :

La sécurité informatique utilise un vocabulaire bien défini. Pour bien comprendre ce vocabulaire, il est nécessaire de définir certains termes :

Les vulnérabilités : ce sont les failles de sécurité dans un ou plusieurs systèmes. Tout système vu dans sa globalité présente des vulnérabilités, qui peuvent être exploitables ou non.

Les attaques (exploits) : elles représentent les moyens d'exploiter une vulnérabilité. Il peut y avoir plusieurs attaques pour une même vulnérabilités mais toutes les vulnérabilités ne sont pas exploitables.

Les contre-mesures : ce sont les procédures ou techniques permettant de résoudre une vulnérabilité ou de contrer une attaque spécifique (auquel cas il peut exister d'autres attaques sur la même vulnérabilité).

Les menaces : ce sont des adversaires déterminés capables de monter une attaque exploitant une vulnérabilité.

III- Les objectifs de la sécurité informatique :

La sécurité informatique à plusieurs objectifs, bien sûr liés aux types de menaces ainsi qu'aux types de ressources. Néanmoins, les principaux points sont les suivants :

- empêcher la divulgation non autorisée de données
- empêcher la modification non autorisée de données
- empêcher l'utilisation non autorisée de ressources réseau ou informatiques de façon générale

Ces objectifs s'appliquent dans différents domaines ou champs d'applications, chacun faisant appel à des techniques différentes pour atteindre le ou les mêmes objectifs; ces champs sont:

- la sécurité physique
- la sécurité personnelle
- la sécurité procédurale (audits de sécurité, procédures informatiques...)
- la sécurité des émissions physiques (écrans, câbles d'alimentation, courbes de consommation de courant...)
- la sécurité des systèmes d'exploitation
- la sécurité des communications

IV- Les menaces :

IV-1- Les virus informatique :

Les virus informatiques sont la forme la plus classique des programmes qui menace votre système. Ils existent depuis le début des PC et sont encore loin d'être éliminé complètement. Ils prennent la forme de petit programme exécutable et s'installe dans le système en corrompant les fichiers importants du système. On les trouve dans le secteur d'amorce des disquettes, en pièces jointes aux courriels ou dans tout autre support de média. Ils ont la propriété de pouvoir modifier leur propre code pour pouvoir passer inaperçu pour facilement lors des vérifications des anti-virus (Polymorphisme). Ils réussissent aussi à s'installer en toute furtivité. Pour certains types de virus, il suffit d'oublier une disquette dans le lecteur lors du démarrage de l'ordinateur pour permettre au virus d'infecter les fichiers essentiels au système.

Un virus reste dans le système aussi longtemps qu'il n'est pas détecté et éliminé du PC. Certains virus peuvent n'avoir aucun effet sur le système et d'autre peuvent formater le disque dur et ainsi faire perdre toutes les données du système. D'autres encore se contenterons de ralentir le système alors que certains attendent à une date précise pour déclancher une avalanche de problèmes.

En générale :

- Un virus est un programme informatique capable d'infecter d'autres programmes en les modifiant afin de s'y intégrer lui-même.
- Il se reproduit rapidement sans que l'utilisateur en ait conscience.
- Il peut causer des dégâts insignifiants ou redoutables : message, destruction, petite musique, ...
- Plusieurs dizaines de nouveaux virus sont créés chaque semaine.

Il existe plusieurs types de virus :

- Les virus de secteur d'amorce (virus de boot)
  Ils remplacent le secteur d'amorce du disque et sont donc chargés au démarrage
- Les virus d'applications : ils infectent les fichiers exécutables, c.a.d. Les programmes (.exe, .com, .sys, .scr, .vbs, .js, .bat, ...)
- Les virus macro infectent uniquement les documents (word, excel,...)
  Ils peuvent causer de grands dégats (formatage du disque dur)
- Les virus de mail ou vers. Ils se servent des logiciels de messagerie (surtout microsoft) pour se répandre à grande vitesse en s'envoyant à toutes les personnes présentes dans le carnet

Pour cela un virus peut avoir les symptômes suivants :

- Ils modifient la première section d'information lue lors du démarrage. Ensuite le virus contamine toutes les disquettes ou les supports amovibles insérés à l'ordinateur.
- Ils modifient aussi l'ordre des opérations du système d'exploitation.
- Affectent la mémoire (l'ordinateur devient très lent).
- Détruisent des fichiers.

- Modifient l'information des fichiers du système d'exploitation.
- Infectent les logiciels de la suite Office.

IV-2- Les vers informatique :

- Contrairement au virus, un ver n'a pas besoin d'infecter un programme.
- Les vers informatiques sont incapables de se reproduire sur un système infecté.
- Un ver informatique se propage en utilisant l'Internet ou l'Intranet.
- Les vers sont généralement distribués à partir des courriels, des forums de discussions et des logiciels P2P (kazaa, Imesh, Napster etc.).
- Certains vers se reproduisent directement par l'intermédiaire des serveurs Web.
- Les vers se reproduisent très rapidement. Ils peuvent infecter des millions de machines en quelques minutes.

IV-3- Les chevaux de troie :

- Les chevaux de troie sont bien souvent plus dangereux qu'un simple virus.
- Les chevaux de troie sont incapables de se reproduire et de se propager par eux-mêmes.
- Les chevaux de troie permettent à l'agresseur de contrôler un ordinateur à distance.
- Les chevaux de troie sont des fichiers exe.
- Les chevaux de troie doivent être exécutés pour que ceux-ci entrent en fonction.

IV-4- Les bombes logiques :

- Les bombes logiques présentent des caractéristiques similaires aux chevaux de Troie (incapacité de se reproduire et de se propager).
- Les bombes logiques sont programmées pour s'activer quand survient un événement précis : une date particulière, une combinaison de touches, une action spécifique ou un ensemble de conditions précises.

- De façon générale, les bombes logiques visent à faire le plus de dégât possible sur le système en un minimum de temps.

IV-5- Les mouchards (Spyware) :

- Le but des mouchards est de recueillir le plus d'information possible de l'utilisateur.
- Conséquences d'être infecté d'un mouchard :Ils notent les sites Web que vous avez visités;
  - Ils récupèrent les mots clés soumis aux moteurs de recherche;
  - Ils récupèrent les informations soumises dans des formulaires Web;
  - Ils récupèrent les informations concernant les achats en ligne (numéro de carte bancaire).
- Ces mouchards sont présents dans de nombreux « freewares » ou « sharewares » et ils s'installent lors des téléchargements à l'insu des utilisateurs.
- Certains de ces éditeurs signent des contrats avec de grandes sociétés de marketing.
- D'après plusieurs sites spécialisés dans la défense de la vie privée, plus de 1 200 logiciels libres de droits seraient "infectés" par une forme ou une autre de mouchard.

IV-6- Les composeurs automatiques (Dialers) :

- Un composeur automatique ou «dialer» est un programme de numérotation téléphonique permettant d'acquérir des contenus payants par Internet et dont les frais sont reliés à votre facture de télécommunication.
- Les internautes téléchargent fréquemment des composeurs automatiques sans se rendre compte. Ces composeurs automatiques sont fréquemment insérés dans les fenêtres de type «popup».

IV-7- Les canulars (Hoaxes) :

- Le rôle principal d'un canular est de vous informer d'une information incorrecte.

- Exemple: Ils peuvent vous faire effacer un ficher important de votre système d'exploitation.

Les canulars les plus populaires sont :

- Des faux virus
- Des chaînes de solidarité
- Des informations incorrectes
- Les arnaques

V- Les contres mesures :

V-1- Antivirus :

1- Définition :

Un antivirus est un logiciel capable d'identifier un virus tentant de s'introduire dans le système d'exploitation, ou dans un quelconque fichier, stocké sur le disque dur de l'ordinateur.

L'antivirus est censé bloquer la tentative d'infection, et prévenir l'utilisateur par une alerte.

De nombreux logiciels antiviraux existent sur le marché, qu'ils soient gratuit ou non. Cependant, aucun d'entre-eux ne peut se targuer d'être infaillible, car de nouveaux virus sont répandus chaque jour.

2 –Rôle des logiciels antivirus.

Ils peuvent chercher un ou des virus (scan) de différentes façons

- chercher une chaîne répertoriée (base de données) identifiant un virus connu
- identifier les virus résidents par examen de la mémoire vive
- chercher les modifications d'allocation mémoire des fichiers et applications induites par les virus
- tracer les accès mémoire dus aux virus
- chercher les chaînes et activités supectes (nouveaux virus) par méthode heuristique (techniques de réseaux neuraux, systèmes experts)

Ils doivent pouvoir réparer

- les dommages dus aux virus (les supprimer en restaurant les données corrompues)

Ils doivent pouvoir protéger

- l'ordinateur contre toute attaque de virus connu ou probable, y compris les macrovirus
- par examen des supports mémoire (disquettes, cartouches)
- par examen de tout fichier téléchargé (dans une zone "sensible" définie comme zone de téléchargement)

Ils doivent être mis à jour régulièrement

- envoi de disquettes, fichiers sur les CD-ROM des magazines d'informatique
- surtout, téléchargement des mises à jour par modem ou par internet .

V-2 Anti spam :

Définition :

Qualificatif appliqué à un logiciel qui permet de se prémunir contre le spam ou à une fonctionnalité d'un logiciel non exclusivement dédié à cette tâche.

Un logiciel anti-spam a pour vocation de limiter le volume de courriels non sollicités par leurs destinataires et/ou d'en faciliter le traitement.

De tels logiciels peuvent être déployés à chaque maillon de la chaîne qu'un e-mail parcourt lorsqu'il est acheminé de son expéditeur à son destinataire (sur le serveur gérant l'envoi, sur celui gérant la réception, voire sur l'ordinateur du destinataire).

Ces logiciels reposent pour la plupart sur l'analyse du titre et du texte du message et sur la mise en oeuvre de filtres.

Il existe des logiciels qui, sans être spécifiquement dédiés à lutter contre le spam, permettent d'en faciliter le traitement. Ainsi, le client de messagerie électronique Mozilla Mail offre une fonctionnalité qui déplace automatiquement tout message identifié comme non sollicité dans un dossier prévu à cet effet.

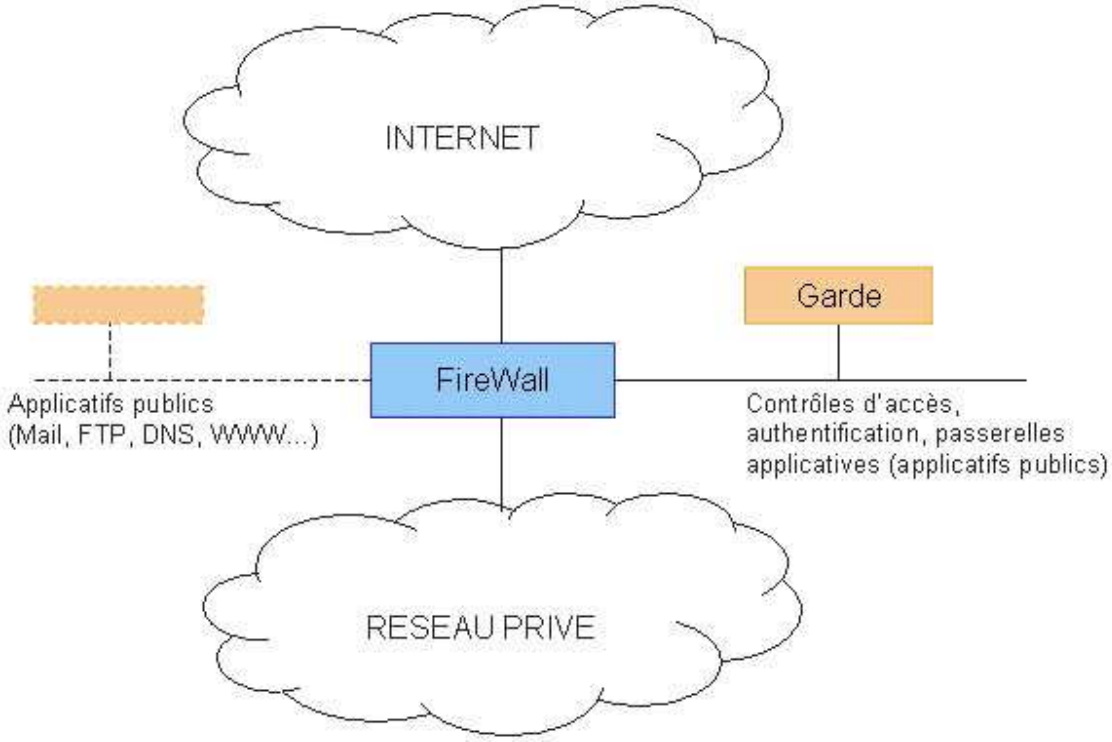
V-3 Firewall (pare-feu) :

1- Définition

Un pare-feu (firewall en anglais), est un système physique (matériel) ou logique (logiciel) servant d'interface entre un ou plusieurs réseaux afin de contrôler et éventuellement bloquer la circulation des paquets de données, en analysant les informations contenues dans les couches 3, 4 et 7 du modèle OSI. Il s'agit donc

d'une machine (machine spécifique dans le cas d'un firewall matériel ou d'un ordinateur sécurisé hébergeant une application particulière de pare-feu) comportant au minimum deux interfaces réseau :

- une interface pour le réseau à protéger (réseau interne)
- une interface pour le réseau externe



Le pare-feu représente ainsi généralement dans les entreprises un dispositif à l'entrée du réseau qui permet de protéger le réseau interne d'éventuelles intrusions en provenance des réseaux externes (souvent internet). Les terminologies suivantes sont parfois également utilisées :

- garde-barrière (gate-keeper)
- porte coupe-feu
- antéserveur
- écluse

2- Rôle

Les pare-feux sont utilisés principalement dans 4 buts :

✓ Maintenir des personnes dehors

En effet, pour se protéger des malveillances "externes", les FireWalls permettent d'écarter divers intrus comme :

- les curieux qui génèrent du trafic, qui font plus de peur que de mal, mais qui quelquefois finissent par coûter cher
- les vandales, ceux qui veulent embêter pour embêter, (saturation de liaisons, saturation de CPU, corruption de données, mascarade d'identité...)
- les espions (problème de confidentialité de l'information)

✓ Maintenir des personnes à l'intérieur

Les pare-feux ont également pour objectif d'éviter la fuite d'information non contrôlée vers l'extérieur.

✓ Contrôler les flux

Tous les flux du trafic entre le réseau interne et externe doivent être surveillés. Cela permet par exemple d'avoir une vue de la consommation Internet des différents utilisateurs internes et de bloquer l'accès à certains sites contenant des informations illégales. Les garde-barrières effectuant un filtrage applicatif (notion expliquée dans le partie suivante) peuvent effectuer des vérifications sur les e-mail reçus et donc interdire les spams. Enfin, un firewall permet un audit de façon "centrale" du trafic pour aider à prévoir les évolutions du réseau.

✓ Faciliter l'administration du réseau

Sans Firewall, chaque machine du réseau est potentiellement exposée aux attaques d'autres machines d'Internet. Les Firewall simplifient la gestion de la sécurité et donc l'administration du réseau car ils centralisent les attaques potentielles au niveau du Firewall plutôt que sur le réseau tout entier.

3- Le fonctionnement d'un système pare-feu

Un système pare-feu contient un ensemble de règles prédéfinies permettant :

- Soit d'autoriser uniquement les communications ayant été explicitement autorisées.
- Soit d'empêcher les échanges qui ont été explicitement interdits.

Le choix de l'une ou l'autre de ces méthodes dépend de la politique de sécurité adoptée par l'entité désirant mettre en oeuvre un filtrage des communications. La

première méthode est sans nul doute la plus sûre, mais elle impose toutefois une définition précise et contraignante des besoins en terme de communication.

Il existe deux types de filtrage pour un firewall : le filtrage de paquets et le filtrage applicatif.

✓ **Le filtrage de paquets**

Le fonctionnement des systèmes pare-feu est basé sur le principe du filtrage de paquets IP, c'est-à-dire sur l'analyse des en-têtes des paquets IP échangés entre deux machines.

Ainsi, lorsqu'une machine de l'extérieur se connecte à une machine du réseau local, et vice-versa, les paquets de données passant par le firewall contiennent les en-têtes suivants, qui sont analysés par le firewall :

- L'adresse IP de la machine émettrice
- L'adresse IP de la machine réceptrice
- Le type de paquet (TCP, UDP, ...)
- Le numéro de port (rappel : un port est un numéro associé à un service ou une application réseau)

Lorsque le filtrage est basé sur les adresses IP, on parle de filtrage par adresse (adress filtering), tandis que le terme de filtrage par protocole (protocol filtering) est utilisé lorsque le type de paquets et le port sont analysés.

Certains ports sont associés à des service courants (les ports 25 et 110 sont généralement associés au courrier électronique, et le port 80 au Web) et ne sont généralement pas bloqués. Toutefois, il est recommandé de bloquer tous les ports qui ne sont pas indispensables (selon la politique de sécurité retenue).

Notons que les firewalls filtrants n’effectuent aucun contrôle d’authentification, les utilisateurs ne sont identifiés que par leurs adresses IP, ce qui peut être problématique si l’on utilise du DHCP et que l’on filtre par adresse IP. Contrairement aux proxys, les firewalls filtrants sont transparents pour les utilisateurs, ceux-ci n’ont pas à configurer leurs applications pour accéder à Internet.

En résumé, le filtrage de paquets présente des avantages en terme de :

- gain de temps pour la mise en place
- coût généralement faible
- performances assez bonnes
- transparence aux utilisateurs et aux applications

Cependant, le besoin croissant de sécurité et de contrôle du contenu informationnel des échanges met en évidence les limites de ce type de firewall :

- L'élaboration de règles de filtrage peut être une opération pénible à partir du moment où l'administrateur réseau doit avoir une compréhension détaillée des différents services Internet et du format des en-têtes des paquets. Si des règles complexes de filtrage doivent être mises en place, c'est un processus long, lourd et difficile à faire évoluer et à comprendre. De plus, une mauvaise configuration peut conduire le site à rester vulnérable à certaines attaques.
- Le firewall filtre de paquets ne protège pas contre les applications du type Cheval de Troie car il n'analyse pas le contenu des paquets. Il est donc possible de tenter une attaque par tunneling de protocole, c'est à dire passer par les protocoles autorisés pour en atteindre d'autres interdits.
- Plus le nombre de règles à appliquer est grand, plus les performances du firewall diminuent, diminuant d'autant les performances de tout le système. On doit alors faire ici un choix parfois crucial entre performance et sécurité.
- Le firewall filtrant n'est pas capable de comprendre le contexte du service qu'il rend : il ne peut par exemple pas bloquer l'importation de mail concernant certains sujets

✓ **Le filtrage applicatif**

Le filtrage applicatif permet, comme son nom l'indique, de filtrer les communications application par application, ce qui signifie qu'il travaille au niveau de la couche 7 du modèle OSI. Le filtrage applicatif suppose donc une connaissance de l'application, et notamment de la manière utilisée pour structurer les données échangées. Un firewall effectuant un filtrage applicatif est appelé passerelle applicative car il permet de relayer des informations entre deux réseaux en effectuant un filtrage fin au niveau du contenu des paquets échangés. Il s'agit donc d'un dispositif performant assurant une bonne protection du réseau, pour peu qu'il soit correctement administré.

Avec ce type de filtres, les politiques de sécurité sont plus flexibles et efficaces car toutes les informations contenues dans les paquets peuvent être utilisées pour écrire les règles servant à déterminer les paquets bloqués par le filtre.

Les avantages des Firewalls filtrant au niveau application sont les suivants :

- Les filtres au niveau application donnent à l'administrateur un contrôle complet sur chaque service par la restriction sur les commandes utilisables et sur l'accès aux hôtes internes par ces services.
- Les filtres au niveau application permettent l'installation de procédures d'authentification extrêmement poussées.
- Les règles d'un firewall filtrant au niveau application sont bien plus faciles à configurer et à tester que pour un firewall filtre de paquets.

En contrepartie, les limitations des filtres au niveau application sont :

- Les filtres au niveau application augmentent considérablement le coût du firewall, ce coût étant principalement lié à celui de la plate-forme matérielle de la passerelle, des services proxy et du temps et des connaissances requises pour configurer cette passerelle.
- Les filtres au niveau application ont tendance à réduire la qualité du service offert aux utilisateurs tout en diminuant la transparence du système.
- Une analyse fine des données applicatives requiert une grande puissance de calcul et se traduit donc souvent par un ralentissement des communications.

4- Limites des firewalls :

Le garde-barrière ne constitue qu'un morceau du casse-tête et reflète la partie de la politique de sécurité qui porte sur le contrôle d'accès. Un firewall ne protège pas des attaques dirigées vers les données (virus, chevaux de Troie, pièces jointes d'un message électronique, Java et Active-X).

Les firewalls ne protègent pas très bien des virus car il y a trop de manières différentes de coder des fichiers pour les transférer. En d'autres termes, un firewall ne pourra pas remplacer l'attention et la conscience des utilisateurs qui doivent respecter un certain nombre de règles pour éviter les problèmes... La première étant bien évidemment de ne jamais ouvrir un fichier attaché à un mail sans être sûr de sa provenance. Il faut prendre des mesures globales et importantes contre les virus. Avant de traquer les virus à l'entrée du réseau, il faut s'assurer que chaque poste de

travail dispose d'un anti-virus. Les virus passent également très facilement par disquette... Les virus sur Internet son bien moins importants que les virus sur disquette.

Il est impossible de confirmer la source des données qui traversent un garde-barrière, ainsi ce dernier ne peut ni en assurer l'intégrité ni protéger leur source. Il ne fait que transférer les données d'un réseau à l'autre et est incapable de détecter si elles ont été modifiées en transit.

Un garde-barrière est incapable d'assurer la confidentialité des données. Une fois qu'il a permis l'accès à des données, il ne peut en maintenir le contrôle. De cette manière, les messages électroniques ou mots de passes d'authentification en clair peuvent être lus pendant leur traversée du réseau. Enfin, les firewalls ne prémunissent pas les réseaux des techniques d'écoute ou de "sniffing".

V-4- Spyware :

1- Définition et rôle:

Un spyware, en français "espiogiciel" ou "logiciel espion", est un programme ou un sous-programme conçu dans le but de collecter des données personnelles sur ses utilisateurs et de les envoyer à son concepteur ou à un tiers via internet ou tout autre réseau informatique, sans avoir obtenu au préalable une autorisation explicite et éclairée desdits utilisateurs.

Même préalablement informé d'un éventuel tracking, l'utilisateur n'en reste pas moins soumis à une surveillance dont la nature peut s'avérer illégale du point de vue de la législation de son pays. L'analyse de sa navigation sur internet peut ainsi par exemple permettre de déduire et de stocker des informations - réelles ou supposées - sur ses origines raciales, ses opinions politiques, philosophiques ou religieuses ou encore son appartenance syndicale, ce qui est interdit en France sans le consentement de l'intéressé.

Une autre définition du spyware pourrait être un logiciel commercial (disponible dans le commerce) que son mode de financement ou son mode de fonctionnement amène à recueillir puis transmettre à un tiers des données personnelles concernant ses utilisateurs, sans avoir obtenu au préalable une autorisation explicite et éclairée de ces derniers. Les spywares sont donc différents des chevaux de Troie et autres enregistreurs de frappes au clavier (keyloggers),

contrairement à une déformation récente de leur définition, même si ces derniers peuvent également être utilisés pour collecter et envoyer des données sensibles, dans un but cette fois clairement malveillant.

Les spywares sont parfois confondus avec les adwares, ces logiciels dont l'auteur se rémunère par l'affichage de bannières publicitaires, sans pour autant recueillir ni transmettre de données personnelles et sans forcément porter atteinte à la vie privée de leurs utilisateurs (le navigateur Opéra ou le logiciel de messagerie Eudora en version gratuite sont des adwares). Ils sont également confondus à tort avec les cookies et les web-bugs, qui ne sont pas des programmes espions mais plutôt des procédés techniques dont la mise en oeuvre peut être détournée pour porter atteinte à la vie privée.

2- Les types des spywares :

Une première classification des spywares peut être établie en tenant compte de leur fonction, à savoir le commerce ou le renseignement :

Les spywares commerciaux collectent des données sur leurs utilisateurs et interagissent de manière visible avec eux, en gérant l'affichage de bannières publicitaires ciblées, en déclenchant l'apparition de fenêtres pop-up, voire en modifiant le contenu des sites web visités afin par exemple d'y ajouter des liens commerciaux. Ce sont les spywares les plus courants. Leur existence est généralement mentionnée dans la licence d'utilisation du logiciel concerné, mais souvent dans des termes ambigus et/ou dans une langue étrangère, ce qui fait que l'utilisateur n'est pas correctement informé. Ils se présentent généralement sous la forme de logiciels gratuits, pour les éditeurs desquels ils constituent une source de revenu ;

Les mouchards collectent également des données sur leurs utilisateurs mais le font dans la plus totale discrétion. La surveillance et la réutilisation éventuelle des données collectées se font à l'insu des utilisateurs, généralement dans un but statistique ou marketing, de débogage ou de maintenance technique, voire de cybersurveillance. L'existence de ces mouchards est délibérément cachée aux utilisateurs. Ils peuvent concerner n'importe quel logiciel, qu'il soit gratuit ou payant, mais de par leur nature ils sont peu fréquent, le risque en terme d'image en cas de découverte et médiatisation de l'existence du mouchard par un utilisateur étant à lui seul dissuasif pour la plupart des éditeurs.

Une seconde classification peut être opérée en fonction de la nature des spywares, à savoir leur constitution logicielle :

Le spyware intégré (ou interne) est une simple routine incluse dans le code d'un programme ayant une fonction propre pour lui donner en plus la possibilité de collecter et de transmettre via internet des informations sur ses utilisateurs. Les logiciels concernés sont par exemple Gator, New.net, SaveNow, TopText, Alexa ou Webhancer ainsi que la totalité des mouchards. Le spyware et le programme associé ne font qu'un et s'installent donc simultanément sur l'ordinateur de l'utilisateur ;

Le spyware externalisé est une application autonome dialoguant avec le logiciel qui lui est associé, et pour le compte duquel elle se charge de collecter et de transmettre les informations sur ses utilisateurs. Ces spywares sont conçus par des régies publicitaires ou des sociétés spécialisées comme Radiate, Cydoor, Conducent, Onflow ou Web3000, avec lesquelles les éditeurs de logiciels passent des accords. Le spyware de Cydoor est par exemple associé au logiciel peer-to-peer KaZaA, et s'installe séparément mais en même temps que lui.
Une nouvelle tendance encore plus contestable concerne les utilisateurs du navigateur Internet Explorer. Certains spywares comme Gator cherchent à s'installer automatiquement sur le poste de l'internaute au moyen de la technologie ActiveX, lors de la visite de pages web peu recommandables

Lexique (Comme complément)

A

Attaque active : Attaque se traduisant par une modification illégale d'un état, par exemple la manipulation des fichiers sur un serveur.

AIS (Automated Information System) : Système d'information automatisé . Terme désignant tous les équipements (de nature matérielle, logicielle, ou "firmware") permettant l'acquisition automatique, le stockage, la manipulation, le contrôle, l'affichage, la transmission, ou la réception de données.

Alert : Message décrivant une circonstance se rapportant à la sécurité réseau. Les alertes viennent souvent de systèmes de surveillance actifs sur le réseau.

Ankle-Biter : Personne voulant devenir Hacker ou Cracker mais ayant très peu de connaissances sur les systèmes informatiques. Ce sont la plupart du temps des jeunes adolescents se servant de programmes faciles à utiliser et provenant d'internet .

Anomaly Detection Model : Système de sécurité détectant les intrusions en recherchant les activités sortant du comportement habituel du système et des utilisateurs.

Application Level Gateway (Firewall) : Un firewall est un système ou une application qui gère l'ensemble des connections TCP lors d'une session réseau. Ces "murs de feu" redirigent souvent les paquets sortants afin d'en camoufler l'expéditeur.

ASIM (Automated Security Incident Measurement) : Evaluation automatique d'un incident de sécurité. Surveille le trafic réseau et collecte des informations sur les éléments du réseau où des activités non autorisées sont détectées.

Assessement : Analyse des vulnérabilités d'un système d'information automatisé consistant en la surveillance et l'inspection du système dans le but d'aider l'administrateur à le sécuriser de la meilleure façon possible.

Attaque : Tentative d'évitement des contrôles de sécurité sur un serveur. Le succès de l'attaque dépend de la vulnérabilité du serveur attaqué, mais si elle réussit,

l'attaquant aura un accès illimité au serveur et pourra faire tout ce qu'il veut (vol, destruction de données...)

Audit : Examination des renseignements et activités dans le but de s'assurer qu'ils respectent les contrôles établis et les procédures opérationnelles.

Audit Trail : Enregistrement de l'utilisation des ressources systèmes sur un ordinateur : identification, fichiers accédés, violations des droits...

Authentication Header (AH) : En-tête d'identification . Champs qui suit l'en-tête IP dans un datagramme IP et qui vérifie la provenance et l'intégrité du datagramme.

Automated Security Monitoring : Gestion automatique de la sécurité. Terme désignant tous les services de sécurité assurant un niveau de protection effectif pour l'environnement matériel, l'environnement logiciel, et toute sorte de données.

B

Back Door : Trou de sécurité laissé volontairement dans le système, souvent sous la forme d'un programme dissimulé, par l'administrateur ou par un hacker ayant obtenu un accès root afin de pouvoir conserver cet accès sans forcer la sécurité du système. Voir le film "Wargames".

BCRCI : Brigade Centrale de Répression du Crime Informatique : Service de la police française.

Biba Integrity Model : Modèle formel de sécurité pour l'intégrité des sujets et objets d'un système.

Bomb : Terme désignant tout type de d'attaque visant à crasher le système cible en utilisant des failles logicielles ou protocolaires.

Brèche : Terme employé lors de la réussite d'une attaque sur un serveur, lors de la pénétration d'un système.

Broadcast : Ping envoyé par l'ordinateur local vers tous les autres ordinateurs du réseau. L'ordinateur local reçois donc les réponses de tout le monde. C'est utile lorsque qu'un ordinateur recemment connecté à un réseau veut connaitre les adresses IP de tout les autres ordinateurs.

Buffer Overflow : Phénomène se produisant lorsque le tampon (buffer) ne peut pas traîter correctement toutes les données qu'il reçoit. Cela arrive quand le taux de transfert de données du destinataire est trop inférieur à celui de l'expéditeur. Un buffer Overflow entraîne très souvent un crash du système cible; c'est pourquoi il peut être utilisé volontairement par un hacker.

Bug : Malfonction d'un programme ou d'un matériel due à une erreur involontaire de programmation ou de construction.

C

C2 : Abréviation de Commandement et Contrôle (Command & Control).

Certifier : Etablir la validité d'un utilisateur ou d'un objet en créant un acompte lui alouant des droits.

Certification : Identification. Vérification de l'identité d'un utilisateur ou de toute autre entité dans un système, le plus souvent par mot de passe, pour lui permettre de gérer les ressources auxquelles il a accès.

CGI : Common Gateway Interface. Le CGI est une méthode permettant de faire interagir des serveurs web et des programmes.

CGI-scripts : Scripts permettant la création de pages web dynamiques et interactives. Les CGI-scripts sont réputés pour être très vulnérables aux attaques.

Clipper Chip : Puce VLSI créée par la NSA pour l'encryption de communications vocales. Ce chip utilise l'ESS (Escrow Encryption Standard) et y ajoute l'algorithme d'encryption Skipjack.

COAST (Computer Operations, Audit, and Security Technology) : Opérations informatiques, surveillance, et technologie de sécurité. C'est un projet multiple, sur lequel travaillent plusieurs laboratoires d'investigation dans la sécurité informatique dans le département des sciences informatiques à la Prude University. Des chercheurs et ingénieurs dans les grandes compagnies et les gouvernements participent également à ce projet. Sa recherche est centrée sur les besoins et limitations du monde réel, avec une focalisation particulière sur la sécurité des systèmes informatiques.

Compromise : Intrusion dans un système ayant pour conséquence la divulgation, la modification, ou la destruction d'informations confidentielles.

Computer Abuse : Activité illégale volontaire qui affecte la disponibilité, la confidentialité, ou l'intégrité des ressources d'un ordinateur. Les "Computer Abuse" comprennent la fraude, le détournement, le vol, l'endommagement, l'utilisation non autorisée, et le refus de service.

Computer Fraud : Crimes informatiques impliquant la modification de données dans le but d'en tirer quelque chose de valeur.

Computer Network Attack : Attaque visant à endommager, dégrader, ou détruire des informations se trouvant dans des ordinateurs ou dans des réseaux informatiques, voire détruire les ordinateurs et les réseaux eux mêmes.

Computer Security : Procédures technologiques de sécurité appliquées à des systèmes informatiques pour assurer la disponibilité, l'intégrité, et la confidentialité des informations contenues dans le système.

Computer Security Incident : Intrusion ou tentative d'intrusion dans un Système d'Information Automatisé (AIS). Ces incidents de sécurité peuvent entraîner de longues investigations sur un grand nombre de systèmes informatiques.

Computer Security Intrusion : Accès non autorisé ou pénétration d'un Système d'Information Automatisé (AIS).

Confidentiality : Confidentialité. Elle assure que les informations resteront secrètes et que seules les personnes autorisées y auront accès.

COPS (Computer Oracle and Password System) : Système de gestion pour les serveurs Unix; c'est un logiciel testant la sécurité de shells scripts et de programmes écrits en C. Il recherche des faiblesses dans leur sécurité et les signale quand il en trouve.

Countermeasures : Contre-mesures. Action, matériel, procédure, technique, ou tout autre mesure réduisant la vulnérabilité d'un système d'information automatisé (AIS). Les contre-mesures destinées à des menaces et vulnérabilités spécifiques nécessitent des techniques plus sophistiquées et peuvent être identifiées à des systèmes de sécurité.

Crack : Outil de Hacking utilisé pour décoder des mots de passe encryptés. Les administrateurs utilisent aussi Crack pour évaluer la faiblesse des mots de passe des utilisateurs inexpérimentés dans le but d'augmenter la sécurité du système.

Cracker : Personne ayant cassé les sécurités d'un système.

Cracking : Action de s'introduire dans un système informatique.

Crash : Faille soudaine et brutale dans un système informatique.

Cryptanalysis :

1) Analyse d'un système de cryptage et/ou de ses entrées/sorties pour en tirer des variables confidentielles et des données sensibles.

2) Action de décrypter des messages sans la connaissance de l'algorithme ou de la clé de cryptage.

Cryptographic Hash Function : Processus qui transforme une valeur d'un ensemble de données de manière que toute manipulation de cet ensemble soit détectable.
Cryptography : Cryptographie . Terme désignant la science, les principes, les moyens, et les méthodes pour rendre un texte incompréhensible et pour convertir les messages cryptés en textes compréhensibles.

Cryptology : Cryptologie. Science se rapportant aux communications camouflées, déguisées, ou cryptées.

Cyberspace: Cyberespace. Terme désignant l'ensemble de tous les ordinateurs connectés et la société assemblée autour d'eux. Le Cyberespace est le plus souvent appelé INTERNET.

D

Datagramme : Packet IP. Cela inclue l'entête IP et les données transportées.

Disponibilité : Elle assure que les informations et les communications seront utilisables quand une requête leur sera formulée.

Dark Side Hacker : Un Hacker criminel ou malveillant.

DARPA (Defense Advenced Reaserch Projects Agency) : Agence de recherche avancée de projets de défense.

Data Driven Attack : Attaque codée en données semblant inoffensives mais pouvant s'avérer dangereuses une fois les défense d'un système dépassées. Le but de ce type d'attaque est le plus souvent de pouvoir passer à travers un Firewall.

Data Encryption Standard :

1) (DES) Algorithme de cryptage adopté par le bureau National des Standards pour une utilisation publique.

2) Algorithme de cryptage pour la protection des données non classées. Le DES, approuvé par l'Institut National des Standards et des Technologies (NIST), est destiné à une utilisation publique et gouvernementale.

Defense Information Operations : Processus qui intègre et coordonne les politiques avec les procédures, les opérations, le personnel, et les technologies pour protéger les informations et défendre les systèmes d'information. Les DIO se servent d'informations, de sécurité physique, d'opérations de sécurité, d'opérations anti-psychologiques et anti-intelligence, de protections électroniques et d'opérations d'information spéciales. Les DIO assurent un accès aux informations précis, rapide, et fiable tout en les protégeant des ennemis voulant les exploiter.

Deamon Dialer : Programme qui appelle systématiquement le même numéro de téléphone. Ces programmes peuvent être autorisés dans la mesure où ils servent a accéder à des BBS, mais ils peuvent aussi être illégaux s'il sont utilisés pour des attaques de type Denial of Service.

Denial of Service : Attaques volontaires visant à empêcher le fonctionnement d'un système d'Information Automatisé (AIS).

Derf : Action d'exploiter un terminal sur lequel quelqu'un s'est déjà identifié et a oublié de fermer sa session.

DNS Spoofing : Utilisation du DNS (Domain Name Server) d'un autre système en corrompant le name service cache d'un système victime, ou en faisant passer un DNS pour un domaine valide.

E

Electronic Attack (EA) : Attaque électronique. Division du EW (voir Electronic Warfare) où l'on utilise l'électromagnétique, l'énergétique, ou les armes anti-radiation dans le but d'attaquer du personnel, des aménagements, ou des équipements avec l'intention de dégrader, neutraliser, ou détruire la capacité de combat ennemie. Une EA inclut : les actions exécutées pour prévenir ou réduire une utilisation ennemie du spectre électromagnétique, telle que le Jamming ou l'utilisation d'armes à mécanisme électromagnétique ou énergétique (lasers, fréquences radio, rayons de particules).

Electronic Protection (EP) : Protection électronique. Division du EW qui représente toutes les mesures prises pour protéger le personnel, les aménagements, et les équipements des effets de l'utilisation ennemie du EW dégradant, neutralisant, ou détruisant les capacités de combat alliées.

Electronic Warfare (EW) : Terme désignant toutes les actions militaires impliquant l'utilisation d'électromagnétique et d'énergétique dans le but de contrôler le spectre électromagnétique ou d'attaquer l'ennemi. Les trois divisions principales de l'Electronic Warfare sont les Attaques Electroniques (EA), la Protection Electronique (EP), et le Support de Guerre Electronique (ES).

Electronic Warfare Support (ES) : Support de Guerre Electronique. Division du EW impliquant l'exécution de tâches par , ou sous contrôle direct d'un Commander opérationnel pour chercher, intercepter, identifier, et situer les sources d'énergie électromagnétique émises intentionnellement ou non dans le but de détecter les menaces. Par conséquent, l'ES fournit les informations nécessaires aux décisions concernant les opérations d'EW et autres opérations tactiques telles que les menaces d'évasion. Les données des ES peuvent être utilisées pour produire des signaux de renseignements.

Encapsulating Security Payload (ESA) : Mécanisme fournissant une protection pour la confidentialité et l'intégrité de datagrammes IP.

Ethernet Sniffing : Programme écoutant l'interface ethernet pour des paquets intéressant l'utilisateur. Quand le programme repère un paquet répondant à certains critères, il copie son contenu dans un fichier. Les critères les plus fréquents pour un paquet intéressant sont des mots tels que "login" ou "password".

F

False Negative : Evénement se produisant quand une intrusion est identifiée comme une non intrusion par le système et la laisse se produire.

False Positive : Evénement se produisant quand un système classe une action comme anormale (par exemple une intrusion) quand il s'agit d'une action légitime.

Fault Tolerance : Capacité d'un système ou d'un composant à continuer de fonctionner correctement malgré la présence de problèmes matériels ou logiciels.

Firewall : Système ou combinaison de systèmes qui renforce la limite entre deux réseaux ou plus. C'est un type de passerelle limitant l'accès entre les réseaux conformément à la politique locale de sécurité. Cette limite est basée sur le filtrage des informations transitant entre les deux réseaux. C'est un outil indispensable de sécurisation.

Fishbowl : Contenir, isoler, et subordonner un utilisateur non autorisé sur un système dans le but d'obtenir des informations sur cet utilisateur.

Flag : Drapeau en français. C'est un indicateur binaire, généralement codé sur un bit.

Flood : Inondation, déluge en français. Type d'attaque réseau qui consiste à envoyer un flux important de packets ou de messages visant à saturer l'ordinateur victime. Cette attaque n'est vraiment valable que si le débit (bande passante) de l'attaquant est supérieur à celui de la victime. Les récentes attaques contre Yahoo et EBay de Mafiaboy sont de ce type.

Fork Bomb : Aussi connu sous le nom de "logic bomb", code pouvant être écrit en une ligne de code sur un système Unix; basé sur une duplication infinie de lui-même, il peut éventuellement "exploser" en détruisant toutes les entrées dans la table des processus et bloquant efficacement le système.

H

Hacker : Personne aimant explorer les détails des systèmes informatiques et comment étendre leurs capacités. Personne malveillante ou curieuse s'intéressant à tout ce qui touche à l'informatique et qui essaie de découvrir le maximum d'information en recherchant partout. Personne aimant apprendre les détails des systèmes de programmation, par opposition à la plupart des utilisateurs qui préfèrent apprendre le minimum nécessaire.

Hacking : Utilisation non autorisée ou tentative de tromper ou de passer outre les mécanismes de sécurité sur un ordinateur ou un réseau.

Hacking Run : Session de Hacking de durée très supérieure à la normale, en particulier celles durant plus de 12 heures.

Host : Un ordinateur simple ou une station de travail; il peut être connecté à un réseau.

Host Based : Information, telle que des données livrées par un audit, provenant d'un simple host qui peut être utilisée pour détecter les intrusions.

I

IDEA (International Data Encryption Algorythm) : Algorithme international d'encryption de données. Algorithme d'encryption - décryption par clé qui utilise une clé deux fois plus longue qu'une clé DES.

IDIOT (Intrusion Detection In Our Time) : Système détectant les intrusions en utilisant le pattern-matching (détection d'opérations inhabituelles).

Information Assurence (IA) : Opérations d'information qui protègent et défendent les informations et les systèmes d'information en assurant leur disponibilité, leur confidentialité, leur intégrité, et leur authenticité. Cela inclut la restauration de systèmes d'information en incorporant protection, détections, et capacités de réaction.

Information Operations (IO) : Opérations d'information. Actions exécutées pour affecter des informations ou systèmes d'information, tout en défendant les siennes.

Information Security : Résultat d'un système de règles et/ou de procédures pour identifier, contrôler, et protéger des informations dont la protection est autorisée par un ordre exécutif.

Information Superiority : Capacité à collecter, traiter, et disséminer un flot ininterrompu d'informations tout en exploitant et en empêchant un ennemi de faire de même.

Information Warfare : Actions effectuées pour achever un "Information Security" en affectant les informations, les processus d'information, et les systèmes d'information ennemis tout en défendant les siens. Action d'exploiter, de

corrompre, de détruire ou d'empêcher le fonctionnement des informations ennemies et de leurs fonctions, tout en protégeant les siennes de ces actions.

Information Warfare (IW) : Opérations d'information conduites pendant une crise ou un conflit pour achever ou faire avancer des objectifs spécifiques sur un ou des ennemis spécifiques.

Intégrité : Assure que les informations ne seront pas, accidentellement ou intentionnellement, altérées ou détruites.

Internet Worm : Programme de type vers qui apparut sur Internet en 1988. Il fut codé par Robert T. Morris dans un but expérimental, mais l'expérience échappa à son contrôle.

Intrusion : Série d'actions tentant de compromettre l'intégrité, la confidentialité, ou la disponibilité d'une ressource.

Intrusion Detection : Techniques tentant de détecter une intrusion dans un ordinateur ou un réseau par l'observation d'actions, de logs de sécurité, ou de données d'audits. Détections d'intrusions (ou tentatives d'intrusions) manuellement ou en utilisant des programmes qui se servent des logs ou autres informations disponibles sur le réseau.

IP Splicing/ Hijacking : Action par laquelle une session active établie est interceptée par un utilisateur non autorisé. Les attaques de type IP Splicing se produisent après l'identification, ce qui permet à l'attaquant d'assumer le rôle d'un utilisateur déjà autorisé. Les protections primaires contre l'IP Splicing consistent en une encyption au niveau de la session ou du réseau.

IP Spoofing : Action par laquelle un système tente de se faire passer illicitement pour un autre système en utilisant son adresse IP.

K

Key : Symbole ou séquence de symboles appliqués à un texte pour le crypter ou le décrypter.

Key Escrow : Système consistant à donner un morceau d'une clé à chacun des dépositaires, de manière que, avec la collaboration de chacun d'eux, la clé puisse être reconstituée dans sa totalité.

Keystore Monitoring : Forme spécialisée d'audit trail, ou matériel spécifique qui enregistre chaque clé tapée par un utilisateur et chaque caractère de la réponse que retourne l'AIS à l'utilisateur.

L

LAN (Local Arena Network) : Réseau Local. Système de communications informatiques limité à quelques kilomètres de distance et utilisant une connexion très rapide (de 2 à 10 Mega-octets par seconde). Système de communications sur courtes distances qui connecte des machines ADP dans un immeuble ou un groupe d'immeubles sur quelques kilomètres carrés, incluant des stations de travail, des processeurs, des contrôleurs, des commutateurs et des gateways.

Leapfrog Attack : Utilisation d'informations sur un UserID et un password obtenus illicitement d'un host pour compromettre un autre host. Action d'établir une connexion TELNET à travers un ou plusieurs hosts dans le but de diminuer les traces laissées.

Letterbomb : Partie d'un e-mail contenant des données ayant pour but d'affecter la machine ou le terminal du receveur. Sous Unix, une Letterbomb peut aussi tenter de faire interpréter son contenu comme une commande shell. Le résultat de ces attaques peut aller d'un simple divertissement à un Denial of Service.

Logic Bomb : Aussi connu sous le nom de Fork Bomb, programme résidant sur un système informatique, qui, quand il est exécuté recherche une condition particulière ou un état particulier du système pour exécuter une action illicite une fois cette condition trouvée.

M

Mailbomb : E-mails envoyés en masse vers un système unique ou une personne unique dans l'intention de Crasher la machine du destinataire. Le Mailbombing est très souvent considéré comme scandaleux.

Malicious code : Matériel, logiciel ou firmware qui est inclus volontairement dans un système dans le but d'y réaliser des opérations illégales (comme par exemple un Cheval de Troie).

Metric : Variable x prise au hasard représentant une mesure quantitative accumulée après une période.

Mimicking : Synonyme de camouflage ou spoofing.

Misuse Detection Model : Le système détecte les intrusions en recherchant les activités qui correspondent à des techniques d'intrusion connues ou à des vulnérabilités systèmes. Aussi connu sous le nom de Rules Based Detection.

Mocking Bird : Programme informatique ou processus qui imite le comportement autorisé (ou tout autre fonction apparemment utile) d'un système normal mais qui exécutes des activités illégales une fois invoqué par l'utilisateur.

Multihost Based Auditing : Système d'audit de hosts multiples pouvant servir à détecter des intrusions.

N

NAK Attack : Technique de pénétration basée sur une faiblesse potentielle d'un système d'exploitation qui ne manipule pas bien les interruptions de désynchronisation et laisse ainsi le système sans protection durant ces interruptions.

National Information Infrastructure (NII) : Interconnections nationales de réseaux de communication, d'ordinateurs, de bases de données, et de consommations électroniques qui forment un grand ensemble d'informations disponible aux utilisateurs. Le NII comprend une large gamme d'équipements tels que des caméras, des scanners, des claviers, des machines fac-similées, des ordinateurs, des CD, des cassettes audio et vidéo, des câbles, des télégrammes, des satellites, des lignes de transmission par fibres optiques, des réseaux, des écrans, des imprimantes… Le personnel allié et ennemi qui prend les décisions et qui manipule les informations transmises constitue une partie critique du NII.

NCSC : voir National Computer Security Center.

Network : Réseau. Deux ou plusieurs machines connectées pour des communications.

Network Based : Trafic de données d'audits provenant de hosts et utilisés pour détecter les intrusions.

Network Level Firewall : Firewall analysant le trafic au niveau des paquets de protocole réseau (IP).

Network Security : Sécurité réseau. Protection des réseaux et de leurs services de modifications illicites, destruction, ou accès non autorisé à des ressources; et mesures de précautions assurant que le réseau exécute correctement ses fonctions critiques et qu'il n'y a pas d'effets nuisibles. La Sécurité Réseau inclut des vérifications d'intégrité des données.

Network Security Officer : Particulier nommé par une autorité désignée pour garantir que les mesures de sécurité et toutes les directives applicables sont implémentées sur le cycle de vie d'un AIS.

Network Weaving : Autre nom du "Leapfrogging".

Non-Discretionnary Security : Aspect de la politique de sécurité du DoD qui limite l'accès aux niveaux de sécurité de base. Un niveau de sécurité est composé d'un niveau de lecture et d'un niveau de réglage des restrictions. Pour un accès en lecture sur une ressource, un utilisateur doit avoir un accès d'un niveau identique ou plus élevé que celui de l'information et doivent avoir aussi accès à toutes les catégories incluses dans les catégories spécifiées pour l'accès à cette ressource.

Non-Repudiation : Méthode par laquelle l'expéditeur de données donne une preuve d'envoi et le receveur est assuré de l'identité de l'expéditeur, pour que personne ne puisse, par la suite, nier avoir traité ces données.

O

Open Security : Environnement ne fournissant pas un niveau de sécurité suffisant pour les applications et les équipements contre des pénétrations sur le système.

Open Systems Security : Réserve d'outils pour un travail Internet sécurisé entre systèmes ouverts.

Operational Data Security : Protection de données contre des modifications accidentelles ou illicites, la destruction, ou la révélation durant des opérations d'entrée ou sortie ou de traitement de ces données.

Operational Security :

1/ Action de renier les informations adverses sur les intentions et capacités alliées en identifiant, contrôlant et protégeant les indications sur les projets ou l'exécution d'opérations militaires ou autres activités.

2/ Processus d'analyse par lequel le gouvernement des Etats-Unis peut renier les informations adverses potentielles sur ses intentions et capacités, en identifiant, contrôlant et protégeant les projets et exécutions d'opérations et activités sensibles.

Operations Security (OPSEC) : Processus d'identification d'informations critiques et d'analyse des actions alliées en rapport avec des opérations militaires et autres activités, dans le but de :

a/ Identifier les actions qui peuvent être observées par les systèmes d'information ennemis.

b/ Déterminer les indications pouvant être obtenues par des systèmes d'information hostiles et pouvant être interprétés ou rassemblées pour en tirer des informations utiles aux ennemis.

c/ Sélectionner et exécuter des mesures éliminant ou réduisant les vulnérabilités d'actions alliées.

Orange Book : Voir Trusted Computer Security Evaluation Criteria.

OSI (Open Systems Interconnection) : Connexion de systèmes ouverts. Ensemble de standards reconnus internationalement et développés ouvertement ayant besoin d'administrer des ressources réseau.

P

Packet : Bloc de données envoyées sur le réseau transmettant : les identités des stations sources et destinations, les informations de contrôle d'erreur, et les messages. Synonyme de "trame".

Packet Filter : Inspecte chaque paquet pour trouver un type de contenu défini par l'utilisateur, tel que une adresse IP, mais ne trace pas l'état des sessions. C'est un des types de Firewall les moins securisés.

Packet Filtering : Caractéristique incorporée aux routeurs limitant le flux d'informations basées sur les communications prédéfinies telles que la provenance, la destination, ou le type de service fourni par le réseau. Les filtreurs de paquets permettent aux administrateurs de limiter le trafic de protocoles spécifiques, d'isoler les domaines de mail, et d'exécuter d'autres fonctions de contrôle du trafic.

Packet Sniffer : Appareil ou programme qui gère les échanges de données entre deux ordinateurs d'un réseau.

Passive Attack : Attaque ne résultant pas en un changement d'état illicite; telle qu'une attaque qui observe et enregistre seulement des données.

Passive Threat : Menaces de révélations illicites d'informations sans changement d'état du système. Type de menace impliquant l'interception et non l'altération d'informations.

PEM (Privacy Enhanced Mail) : Standard IETF servant à sécuriser les échanges de courrier électronique.

Penetration : Réussite d'un accès non autorisé sur un système automatique.

Penetration signature : Description d'une situation ou d'une série de conditions dans lesquelles une pénétration pourrait se produire, ou d'événements système qui, assemblés, peuvent indiquer une pénétration en cours.
Penetration testing : Partie du Security Testing dans laquelle les évaluateurs tentent de tromper les sécurités d'un système. Les évaluateurs doivent assurer l'utilisation de toute l'architecture du système et de la documentation implémentée; cela peut inclure le listage du code source du système, des manuels, des diagrammes de circuit. Les évaluateurs travaillent sous les mêmes contraintes que celles appliquées aux utilisateurs ordinaires.

Perimeter Based Security : Action de sécuriser un réseau en contrôlant l'accès à toutes les entrées et sorties du réseau. Cette technique est souvent associée avec des firewalls et/ou des filtres.

Perpetrator : Entité de l'environnement externe pouvant représenter un risque. Entité de l'environnement externe exécutant une attaque; par exemple un Hacker.

Personnal Security : Procédures établies dans le but d'assurer que le personnel qui a accès a des informations classées disposes des autorisations requises.

PGP (Prettu Good Privacy) : Programme gratuit (freeware) utilisé principalement pour sécuriser le courrier électronique.

Phage : Programmes modifiant d'autres programmes ou des bases de données de façon illicite; par exemple, un programme propageant un virus ou un cheval de troie.

PHF: Programme de démonstration de fichier d'annuaire (Phone book file) que les Hackers utilisent pour gagner l'accès à un système informatique et pour lire et capturer des fichiers password.

PHF hack : CGI script connu pour sa vulnérabilité qui ne filtre pas les caractères spéciaux (ajout d'une ligne par exemple) tapés par l'utilisateur.

Phraker : Personne combinant le phreaking téléphonique et le hacking informatique.

Phreak(er) : Personne fascinée par les systèmes téléphoniques. C'est habituellement une personne utilisant ses connaissances sur les systèmes téléphoniques afin de faire payer ses appels par quelqu'un d'autre.

Phreaking : L'art et la science de pirater le réseau téléphonique.

Physical Security : Mesures utilisées pour fournir des protections physiques aux ressources contre les menaces délibérées et accidentelles.

Piggy Back : Action d'obtenir un accès non autorisé sur un système par la connexion légitime d'un autre utilisateur.

Ping : Requête IP envoyée par l'ordinateur local demandant une réponse à l'ordinateur distant. Sert à connaitre si un ordinateur est connecté à un réseau et qu'il supporte IP.

Ping Of Death : Utilisation d'un ping avec un paquet de taille supérieure a 65507. Ce type d'attaque entraîne un Denial of Service.

Plain Text : Données non cryptées. Synonyme de "en clair".

Port : Interface logique de communication entre deux ordinateurs. Exemple : en TCP/IP, le port 21 est celui de FTP, 80 celui de http, etc...

Private Key Cryptography : Méthode d'encryption où l'encrypteur et le décrypteur utilisent la même clé qui doit rester secrète. Cette méthode n'est utilisée habituellement que par des petits groupes.

Probe : Effort visant à rassembler des informations sur une machine ou sur ses utilisateurs dans le but évident de gagner plus tard un accès illicite sur le système.

Procedural Security : Voir Administrative Security.

Profile : Modèle d'activité pour un utilisateur pouvant détecter les changements dans les routines habituelles.

Promiscuous Mode : Habituellement, une interface Ethernet lit toutes les informations d'adressage et accepte uniquement les paquets lui étant exclusivement destinés; mais quand l'interface est en Promiscuous Mode, elle lit toutes les informations (sniffer) en portant peu attention à la destination.

Protocol : Méthodes universelles de communication utilisées par les Ordinateurs. Spécification décrivant les règles et les procédures que les produits doivent suivre pour pouvoir effectuer des activités telles que la transmission de données sur un réseau. Si ils utilisent les mêmes protocoles, les produits de constructeurs différents doivent pouvoir communiquer sur le même réseau.

Prowler : Robot effectuant régulièrement des tâches telles que rechercher et effacer des fichiers core, tronquer des logs de fichiers d'administration, détruire des répertoires perdus, et nettoyer le système.

Proxy : Mécanisme de type firewall qui remplace l'adresse IP d'un host sur un réseau interne par sa propre adresse IP pour tout le trafic circulant. Programme agissant selon les directives d'un utilisateur, les proxys caractéristiques acceptent une connexion d'un utilisateur, décident si l'utilisateur ou l'adresse IP du client est autorisée à utiliser le proxy, avec une éventuelle authentification, et complète ensuite une connexion vers la destination demandée par l'utilisateur.

Psycological Operations (PSYP) : Opérations organisées pour transmettre les informations et indication choisies à des gouvernements, groupes, organisations, ou particuliers étrangers dans le but d'influencer leurs émotions, leurs motivations, leurs raisonnements, et leur comportement. Le but de ces opérations psychologiques est d'induire ou de renforcer les attitudes et comportements étrangers en faveur des objectifs de l'initiateur de ces opérations.

Public Key Cryptography : Type de cryptographie dans lequel le processus d'encryptions est disponible au public et non protégé; mais dans lequel la clé de décryptions est protégée de telle sorte que seul un groupe ayant connaissance des deux parties du processus de décryptions puisse décrypter le texte crypté.

R

Red Book : Voir Trusted Network Interpretation.

Reference Monitor : Concept de contrôle de sécurité dans lequel une machine virtuelle gère l'accès à des objets. En principe, un Reference Monitor devrait être complet (lorsque il gère tous les accès), isolé des modifications par les entités système, et son état vérifiable. Un centre de sécurité (Security Kernel) est une implémentation d'un Reference Monitor dans une base matérielle donnée.

Replicator : Programme agissant pour produire des copies de lui-même, ça peut être par exemple un programme, un Worm, une ForkBomb, ou un virus. Il est souvent dit que Unix et le C sont les deux moitiés pouvant amener à la création de Replicators très performants.

Retro-Virus : Un retro-virus est un virus qui attend jusqu'à ce que tous les médias disponibles soient aussi infectés pour qu'il ne soit plus possible de restaurer l'état normal du système.

Rexd : Cette commande Unix est celle du server Sun RPC pour l'exécution distante de programmes. Un bot lance les programmes dès qu'une requête est formulée.

Risk Assessement : Etude des vulnérabilités, menaces, probabilités, pertes et de l'efficacité théorique des mesures de sécurité. Procédure d'évaluation des menaces et vulnérabilités connues pour déterminer les pertes attendues et pour établir le degré de sécurité des opérations système.

Risk Management : Procédure visant à identifier, contrôler, et minimiser l'impact d'événements variables. Les objectifs des programmes de Risk Management sont de réduire les risques et obtenir et maintenir la DAA (Designated Approving Authority).

Rootkit : Outils de sécurité utilisés par les Hackers qui capture les mots de passe et le trafic de messages depuis et vers un ordinateur. Ensemble d'outils permettant au Hacker d'introduire une BackDoor dans un système, de collecter des informations sur les autres systèmes du réseau, de masquer les modifications qu'il a apporté au système… Un Rootkit est un des exemples classique des logiciels type Cheval de Troie. Des Rootkit sont disponibles pour un large panel de systèmes d'exploitation.

Router : Connexions d'appareils similaires à des ponts mais transportant des paquets et des trames contenant certains protocoles. Les routeurs relient les LAN au niveau de la couche réseau.

Routing Control : Application de règles durant l'exécution de tâches de routage dans le but de pouvoir choisir d'éviter des réseaux, liens ou relais spécifiques.

RSA Algorithm : RSA pour Rivest-Shanir-Aldman. Algorithme d'encryptions à clé publique simulant un système de cryptage très complexe.

Rules Based Detection : Système de détection d'intrusions recherchant des activités correspondant à des techniques d'intrusion connues (signatures) ou à des vulnérabilités système. Aussi connu sous le nom de Misuse Detection.

S

Samourai : Hacker proposant ses services pour des travaux de cracking légaux ou tout autre travail légitime nécessitant l'intervention d'un serrurier de l'électronique.

SATAN (Security Administration Tool For Analysing Networks) : Outil servant à sonder et identifier à distance les vulnérabilités de systèmes sur des réseaux IP. Programme puissant et gratuit aidant à identifier les faiblesses de sécurité système.

Secure Network Server : Appareil qui agit comme un portail entre une enclave protégée et le monde extérieur.

Secure Shell : Connexion shell entièrement cryptée entre deux machines et protégée par une phrase très longue pour mot de passe.

Sécurité administrative : Gestion limitée et contrôles supplémentaires des données afin de leur fournir un niveau de protection suffisant.

Security : Condition résultant de la mise en place et de la maintenance de mesures de protection assurant un état d'inviolabilité contre les actions ou influences hostiles.

Security Architecture : Description détaillée de tous les aspects du système se rapportant à la sécurité, accompagnée d'une série de principes guidant les projets. Une Architecture de Sécurité décrit la façon dont le système devrait être assemblé pour satisfaire le niveau de sécurité requis.

Security Audit : Recherche effectuée sur un système informatique visant à découvrir des problèmes et vulnérabilités de sécurité.

Security Countermeasures : Contre mesures destinées à des menaces et vulnérabilités spécifiques ou entraînant la mise en place de nouvelles activités de sécurité.

Security Domains : Ensemble d'objets auquel un sujet à la capacité d'accéder.

Security Features : Ensemble de mécanismes, fonctions et caractéristiques matérielles et logicielles d'un AIS relevant de la sécurité.

Security Incident : Action ou circonstance impliquant des informations classées dont les conditions varient de celles décrites par les publications de sécurité des administrateurs. Par exemple des compromis, des révélations de données, des détournements.

Security Kernel : Eléments matériels, logiciels, et firmware d'une Trusted Computing Base qui implémente les références d'un concept de surveillance. Un Security Kernel doit gérer tous les accès, doit être protégé des modifications extérieures, et son état doit être vérifiable.

Security Label : Partie sensible d'une information d'un sujet ou d'un objet, telle que sa classification hiérarchique (confidentiel, secret, top secret) ou une catégorie de sécurité non hiérarchique à laquelle il appartient (par exemple compartiment des informations sensibles, des informations critiques sur la fabrication d'armes nucléaires).

Security Level : Combinaison d'une classification hiérarchique et d'une série de catégories non hiérarchiques représentant la sensibilité d'une information.

Security Officer : ADP officiel ayant la responsabilité de la sécurité d'un système ADP.

Security Perimeter : Limite à l'intérieur de laquelle les contrôles de sécurité sont effectifs pour protéger le système.

Security Policies : Série de lois, règles et pratiques régulant les moyens utilisés par une organisation pour gérer, protéger et distribuer des informations sensibles.

Security Policy Model : Présentation formelle des politiques de sécurité appliquées par un système. Ce modèle doit identifier la série de règles et pratiques régulant les moyens utilisés pour gérer, protéger et distribuer des informations sensibles.

Security Requirement : Types et niveaux de protection nécessaires aux équipements, aux données, aux informations, aux applications, et aux aménagements.

Security Service : Service, fournit par un ensemble de systèmes ouverts communiquant, qui assure une sécurité adéquate pour les systèmes ou les transferts de données.

Security Violation : Circonstance dans laquelle un utilisateur ou une autre personne trompe ou déjoue les contrôles d'un système pour obtenir un accès non autorisé aux informations contenues sur ce systèmes ou aux ressources système.

SEFTI : Service d'Enquête sur les Fraudes aux Technologies de l'Information : Service de la police française.

Server : Système fournissant de services réseaux tels que le stockage de données et le transfert de fichiers, ou un programme fournissant de tels services. Un bot (qui tourne souvent sur un autre système que celui du serveur) exécute un service pour une personne effectuant une requête.

Signaling System 7 (SS-7) : Protocole utilisé par les compagnies de téléphone. Il a trois fonctions de base : superviser, altérer, et adresser. Superviser consiste à examiner les statuts d'une ligne ou d'un circuit afin de déterminer si ils s'ont occupés, inactifs, ou en requête. Altérer consiste à indiquer la provenance d'un appel entrant. Adresser consiste à transmettre des signaux de routage et de destination sur le réseau sous forme de tonalités ou d'impulsions.

Simple Network Management Protocol (SNMP) : Protocole ou Programme utilisé pour contrôler les communications utilisant TCP/IP.

Skipjack : Algorithme d'encryption développé par la NSA pour le Clipper Chip. Les détails de l'algorithme ne sont pas publiés.

Smurfing : Attaque de type Denial of Service dans laquelle l'attaquant camoufle (spoof) l'adresse source d'un paquet ICMP de requête Echo (ping) au broadcast pour un réseau, ce qui entraîne toutes les machines du réseau à répondre en masse à la victime en encombrant de cette façon le réseau.

Snarf : Action de récupérer un fichier ou document important dans le but de l'utiliser, avec ou sans permission de l'auteur.

Sneaker : Particulier qui tente de pénétrer dans de systèmes dans le but de tester leur sécurité; semblable à une tiger team.

Sniffer : Programme capturant des données à travers un réseau informatique. Utilisé par les Hackers pour capturer des login, et des passwords. Outil logiciel qui

surveille et identifie le trafic de paquets réseaux. Un sniffer peut aussi être utilisé légalement par le personnel d'opération et de maintenance du réseau pour résoudre les problèmes liés au réseau.

Spam : Attaque visant à cr asher un programme en faisant déborder un tampon (buffer) de taille fixe avec un trop grand nombre de données entrantes. Peut aussi servir à submerger (flood) une personne ou un newsgroup avec des messages sans rapport avec les autres ou inapropriés.

Special Information Operations (SIO) : Opérations d'information qui par leur nature sensible; a cause de leur effet ou impact potentiel, de leurs besoins en sécurité, ou des risques qu'elles peuvent faire encourir au gouvernement; exigent un examen et un processus d'approbation spéciaux.

SPI (Secure Profile Inspector) : Outil de surveillance réseau pour Unix, développé par le Département de l'Energie.

Spoofing : Action de se faire passe pour quelqu'un d'autre. Incitation délibérée à un utilisateur ou à une ressources à effectuer une action incorrecte. Tentative de gagner l'accès a un AIS en se faisant passer pour un utilisateur autorisé. Les personnifications (Impersonating), les actions de se masquer (Masquerading), et les simulations (Mimicking) sont des formes de spoofing.

SSL (Secure Socket Layer) : Protocole de session par couches fournissant identification et confidentialité aux applications.

Subversion : Se produit lorsque un intrus modifie les opérations du mécanisme de détection d'intrusions pour forcer un False Negative.

Syn Flood : Quand la SYN queue est submergée (flooded), aucune nouvelle connexion ne peut être ouverte.

T

TCP/IP : Transmission Control Protocol / Internet Protocol. Série de protocoles destinés au réseau sur lesquels est basé le réseau Internet.

Tcpwrapper : Outil logiciel fournissant des formes d'identification réseau supplémentaires, te limitant l'accès aux services aux hosts autorisés.

Term Rule Based Security Policy : Politique de sécurité basée sur des règles globales imposées à tous les utilisateurs. Ces règles consistent habituellement en une comparaison entre la sensibilité des ressources étant accédées, et la possession des attributs correspondants pour un utilisateur, un groupe d'utilisateurs ou des entités agissant selon les requêtes des utilisateurs.

Terminal Hijacking : Technique permettant à un attaquant, sur une certaine machine, de contrôler n'importe quelle session active de type terminal. Un Hacker attaquant ainsi peut envoyer et recevoir les entrées/sorties du terminal pendant qu'un utilisateur est sur le terminal.

Threat : Moyens par lesquels les capacités ou les intentions d'une menace visant à affecter les systèmes, aménagements; et des opérations ennemies peuvent être manifestées.

Threat Agent : Méthodes et objets utilisés pour exploiter une vulnérabilité sur un système d'informations, une opération, ou un aménagement.

Threat Assessement : Processus de routine évaluant le degré de menace pour un système et décrivant la nature de la menace.

Tiger : Outil logiciel qui scanne le système à la recherche de faiblesses.

Tiger Team : Equipes d'experts en informatique sponsorisés par les gouvernements et les grandes industries qui tentent de casser les défenses de systèmes informatiques dans le but de découvrir, et éventuellement de corriger, des trous de sécurité.

Tinkerbell Program : Programme de surveillance utilisé pour scanner les connexions réseau entrantes et pour générer des alertes quand des appels sont reçus d'un site particulier, ou quand des tentatives d'identification avec certains login sont effectuées.

Topology : Carte ou plan du réseau. La topologie physique décrit la façon dont les câbles et les fils sont installés, et la Topologie logique ou électrique décrit la façon dont les informations circulent.

Trace Packet : Dans un réseau de communications par paquets, paquet unique envoyant un rapport à chaque stade de sa progression au centre de contrôle réseau depuis chaque élément visité du système.

Traceroute : Action d'envoyer des paquets de type trace pour obtenir des informations; de tracer le chemin emprunté par les paquets UDP depuis le host local jusqu'à un host distant. Habituellement, un traceroute afficher la durée et la localisation du chemin emprunté pour atteindre la destination.

Tranquillity : Modèle de règle de sécurité correspondant à un état pour un objet actif où le niveau de sécurité ne peut pas être changé durant la période d'activité.

Tripwire : Outil logiciel pour la sécurité. Habituellement, il fonctionne avec une base de données qui maintient des informations sur la taille en octets des fichiers. Si la taille change, il prévient le responsable de sécurité du système.

Trojan Horse : Programme en apparence utile et inoffensif mais contenant du code caché supplémentaire permettant de récolter, d'exploiter, de falsifier ou de détruire des données de façon illicite.

Trusted Computer Systèm Evaluation Center (TCSEC) : Système employant suffisamment de mesures de sécurité logicielles et matérielles pour autoriser son utilisation pour des échanges simultanées d'informations et de données sensibles.

Trusted Computing Base (TCB) : Ensemble des mécanismes de protection d'un système informatique incluant le matériel, l'ensemble des logiciels, et le firmware. Une TCB consiste en un ou plusieurs composant qui mis ensembles, renforcent une politique de sécurité appliquée à un produit ou un système.

Trusted Network Interpretation : Caractéristiques de sécurité spécifiques, protection suffisante et structures d'évaluation du livre orange (Orange Book) appliquées à des réseaux informatiques isolés de type LAN ou WAN.

TTY Watcher : Outil utilisé par les Hackers leur permettant, même avec de faibles connaissances, de faire du Terminal Hijacking. Les TTY Watchers utilisent une interface GUI.

V

Vaccines : Programme s'injectant dans un fichier exécutable afin d'en vérifier l'authenticité et d'avertir si un changement est effectué.

Virus : Programme pouvant infecter d'autres programmes en les modifiant pour y ajouter, éventuellement, une copie de lui-même.

Vulnerability : Défaut matériel, logiciel, ou firmware laissant un AIS ouvert à une exploitation potentielle. Faiblesse dans les procédures de sécurité, les contrôles d'administration, les contrôles internes, et autres; sur un systèmes informatisé; pouvant être exploité par une attaque visant à gagner un accès illicite aux informations, ou pour interrompre des processus critiques en cours.

Vulnerability Analysis : Examination systématique d'un AIS ou d'un produit dans le but de déterminer les mesures de sécurité adéquates, identifier les déficiences de sécurité, analyser l'efficacité des mesures proposées, et pour confirmer que de telles mesures seront adéquates une fois implémentées.

W

WAIS (Wide Area Information Service) : Service Internet permettant de rechercher parmi un grand nombre de bases de données classées par catégories.

WAN (Wide Area Network) : Réseau physique permettant à un certain nombre de machines indépendantes de communiquer entre elles par des protocoles de transmission communs sur des zones géographiques plus grandes que celle des réseaux locaux.

War Dialer : Programme composant une liste ou une série de numéros de téléphone et enregistre ceux qui répondent avec des tonalités spéciales, pouvant être des points d'entrée d'ordinateurs ou de systèmes de télécommunications.

Worm : Programme se reproduisant de machine en machine à travers les connexions réseau et les systèmes d'information quand il se répand.

